

Relatório Técnico e Funcional — Sistema Brotar para Aplicativo Mobile

Análise estática e local da plataforma atual

Subsídio técnico para futura definição Android e iOS

06 de agosto de 2026

D:\OneDrive\SISTEMA BROTAR\Sistema-Brotar-v-2.1

Sumário

1. Identificação segura do projeto
 2. Escopo e metodologia
 3. Arquivos e documentos consultados
 4. Resumo executivo
 5. Arquitetura atual
 6. Tecnologias utilizadas
 7. Inventário funcional de módulos
 8. Perfis, permissões e escopos
 9. Fluxos principais
 10. Banco de dados e entidades
 11. Comunicação frontend/backend
 12. Autenticação, autorização e segurança
 13. Funcionalidades com potencial mobile
 14. Recursos nativos aplicáveis
 15. Prontidão técnica para Android e iOS
 16. Componentes reutilizáveis e adaptações
 17. Riscos e limitações
 18. Informações ausentes
 19. Perguntas para a proprietária
 20. Conclusão
-

1. Identificação segura do projeto

1.1 Identidade confirmada

O diretório analisado pertence ao Sistema Brotar, plataforma web de gestão educacional e atendimento multiprofissional da Secretaria Municipal de Educação de Brotas de Macaúbas, Bahia. A aplicação centraliza alunos com necessidades educacionais especiais, escolas, profissionais, agendamentos, prontuários, documentos, relatórios e fluxos internos da rede pública municipal.

- Caminho: `D:\OneDrive\SISTEMA BROSTAR\Sistema-Brotar-v-2.1.`
- Tipo: aplicação web SPA com backend Supabase e APIs auxiliares Node/Vercel.
- Domínio de produção documentado: `brotar.smebrotas.com.br`.
- Versão de código: `2.4.160` em `package.json` e `src/config/version.ts`.
- Versão operacional documentada: `2.4.161` em `AGENTS.md`.
- Confiança: confirmada.

Conclusão: a pasta corresponde inequivocamente ao Sistema Brotar. Evidência: `AGENTS.md`; `.brotar-docs/00-LEIA-PRIMEIRO.md`; `package.json`; `server.mjs`; `src/App.tsx`. Elemento analisado: título do projeto, finalidade, domínio, scripts, rotas e identificação do servidor. Linhas: `AGENTS.md:1-3`; `.brotar-docs/00-LEIA-PRIMEIRO.md:7-27`; `package.json:2-21`; `server.mjs:159-160,634`; `src/App.tsx:349-550`. Confiança: confirmada.

1.2 Resíduos históricos e prevenção de contaminação

Não foi encontrado um segundo projeto funcional independente. Foram identificados resíduos históricos dentro do próprio Brotar:

- `README.md` genérico do AI Studio;

- chaves de armazenamento local com prefixo `nexus_care_*` em `services/storageService.ts`;
- protótipos visuais em `edu/`;
- scripts de diagnóstico e SQLs históricos na raiz;
- componentes antigos coexistindo com a estrutura mais recente de `src/`.

Esses conteúdos não possuem aplicação, dependências e roteamento próprios suficientes para caracterizar outro produto. Foram tratados como legado e não como fonte de verdade quando divergiam do código ativo, das migrations ou da documentação de 06/08/2026.

2. Escopo e metodologia

2.1 Escopo

A análise cobriu somente os arquivos locais do repositório:

- documentação técnica, funcional e operacional;
- configuração de build e deploy;
- frontend React/TypeScript;
- rotas, menus e componentes;
- autenticação, sessão e autorização;
- serviços Supabase;
- APIs Express e Vercel;
- migrations, baseline e SQLs locais;
- entidades, tipos e regras auxiliares;
- testes existentes e seus contratos estáticos;
- nomes de variáveis de ambiente, sem abrir valores.

2.2 Restrições observadas

Não houve:

- acesso ao painel, banco ou Storage remoto do Supabase;
- execução de migrations ou SQL;
- acesso a Meta WhatsApp ou Google Gemini;
- abertura de `.env`, `.env.local` ou valores secretos;
- execução de build, testes de integração remota ou deploy;
- correção ou implementação de código;
- decisão sobre React Native, Flutter, Expo, PWA ou arquitetura nativa.

As afirmações sobre produção são classificadas como documentadas, e não como verificadas remotamente.

3. Arquivos e documentos consultados

3.1 Documentação principal

Documento	Finalidade	Atualidade aparente	Confiabilidade	Principais informações
AGENTS.md	Regras e estado operacional	06/08/2026	Alta	estrutura, roles, migrations, deploy e proibições
.brotar-docs/00-LEIA-PRIMEIRO.md	Baseline do projeto	06/08/2026	Alta	finalidade, stack, produção, banco e decisões críticas
.brotar-docs/01-CONTEXTO-GERAL.md	Contexto e arquitetura	recente	Média/alta	usuários, princípios e estrutura; contém role legado
.brotar-docs/02-MODULOS-DO-SISTEMA.md	Mapa funcional	recente	Média/alta	módulos, arquivos e usuários envolvidos
.brotar-docs/03-HISTORICO-E-DECISOES.md	Histórico técnico	06/08/2026	Alta	V46 pendente, RLS, deploy, duplicados e segurança
.brotar-docs/04-BUGS-E-PENDENCIAS.md	Bugs ativos	06/08/2026	Alta	problemas de UI, V46, credenciais e pendências
.brotar-docs/05-PROMPTS-PRONTOS.md	Procedimentos reutilizáveis	parcialmente antigo	Baixa/média	ainda menciona V39 e deploy Vercel
.brotar-docs/06-REGRAS-DE-TRABALHO.md	Processo de entrega	06/08/2026	Alta	V45 aplicada, V46 não aplicada e sequência de deploy
docs/ARQUITETURA_ATUAL.md	Arquitetura derivada da auditoria	05/08/2026	Alta com ressalvas	alguns achados foram corrigidos posteriormente
docs/AUDITORIA_TECNICA.md	Segurança e dívida técnica	05/08/2026	Alta histórica	achados detalhados, parte desatualizada pelo código atual
docs/MAPA_FRONTEND_BACKEND.md	Contratos por fluxo	05/08/2026	Alta com ressalvas	boa matriz; alguns estados foram corrigidos
docs/BASELINE_BANCO.md	Reprodutibilidade do schema	recente	Alta	instalação limpa bloqueada por dependências ausentes
docs/PLANO_DE_CORRECAO.md	Plano de endurecimento	05/08/2026	Alta	planejamento ainda não integralmente aplicado
docs/PLAN-rls-alunos-vinculo.md	Planejamento histórico de RLS	anterior	Média	parte incorporada em V18-V27
PRD.md e SPEC.md	Produto e referência técnica	engenharia reversa	Média	úteis, mas subordinados a código e migrations
README.md	Instrução inicial	genérico/legado	Baixa	não descreve adequadamente o Brotar
PENDING_TASKS.md	Pendências antigas	21/01/2026	Baixa	cenário anterior às migrations atuais
responsiveness_audit.md	Auditoria responsiva	anterior	Média	problemas relevantes para tablet e celular

3.2 Código e configurações consultados

Foram examinados, entre outros:

- src/App.tsx, src/main.tsx, src/routes/ProtectedRoute.tsx;
- components/Layout.tsx, RoleDashboards.tsx, ClinicalPages.tsx;
- telas de alunos, escolas, agenda, documentos, nutrição, apoio, mensagens, auditoria e administração;
- services/SupabaseService.ts, supabaseClient.ts, geminiService.ts, backupService.ts, storageService.ts;
- server.mjs, server/authorization.mjs, api/_shared/authorization.ts;

- `api/gemini/*`, `api/whatsapp/*`;
- `types.ts`, `src/config/perfilRestrito.ts`;
- `supabase_schema.sql` e `db/migrations/`;
- testes em `tests/`, `api/**/*.test.ts`, `services/*.test.ts` e `utils/*.test.ts`;
- `package.json`, `vite.config.ts`, `vercel.json`, `.htaccess` e `.env.example`.

3.3 Divergências documentais

1. `AGENTS.md` informa 2.4.161; `package.json` e `src/config/version.ts` informam 2.4.160.
2. A documentação recente afirma que `student_documents` não existe no banco; a baseline antiga a define. O código atual usa `students.documents`, `generated_documents` e o bucket `student-documents`.
3. A auditoria de 05/08 afirma que Gemini era chamado no cliente; o código atual usa `/api/gemini/generate` autenticado e mantém a chave no servidor.
4. A auditoria afirmava que perfis inativos não eram recusados; `authenticate` e `getUserProfile` agora exigem `is_active === true`.
5. `/api/whatsapp/send-test` agora exige `admin:manage`, corrigindo achado anterior.
6. Documentos antigos mencionam deploy Vercel; as regras atuais indicam Hostinger servindo `dist/`.
7. Existem duas migrations V38, impedindo ordenação canônica inequívoca.
8. `server/authorization.mjs` aceita `SECRETARIA_EDUCACAO`, inexistente em `types.ts`, e omite `SOCIAL_WORKER`.

4. Resumo executivo

O Sistema Brotar é um produto web funcional e abrangente. Há módulos reais para autenticação, alunos, escolas, agendamento, prontuários, especialidades clínicas, nutrição, profissionais de apoio, documentos, inteligência artificial, WhatsApp, mensagens, relatórios, auditoria, backup e configuração.

A prontidão geral para compartilhar seu backend com um aplicativo Android/iOS é classificada como baixa. A classificação não decorre de ausência funcional, mas da necessidade de estabilizar o perímetro de segurança e os contratos de dados antes de adicionar um novo cliente.

Principais fatores negativos:

- PostgREST, RPC e Storage são acessados diretamente pelo frontend;
- produção documentada permanece em V45, com policies que ainda podem confiar em `user_metadata`;
- V46 tenta migrar a autorização para `profiles`, mas está bloqueada e não aplicada;
- a cadeia de migrations não reproduz integralmente o banco;
- políticas de Storage não estão completamente versionadas;
- uploads usam `getPublicUrl`;
- sessões clínicas e nutrição apresentam lacunas de RLS;
- algumas operações de autoridade são montadas no navegador;
- rotas administrativas têm proteção visual inconsistente;
- homologação não foi confirmada;
- não existe gestão de dispositivos, push, offline ou sincronização mobile.

Pontos positivos:

- Supabase Auth e renovação de sessão já existem;
- perfis inativos são rejeitados no código atual;
- há RLS nos principais domínios;
- existem recortes por escola, região, profissional e especialidade;
- Gemini e envio de WhatsApp usam autorização server-side baseada em `profiles`;
- existe timeout de inatividade;

- agenda e fluxos clínicos oferecem casos mobile claros;
- o domínio possui tipos, validadores e regras reutilizáveis.

Conclusão: há valor mobile comprovável, mas segurança, schema e contratos devem ser estabilizados antes do desenvolvimento. Evidência: `services/SupabaseService.ts`; `db/migrations/V39_fix_clinical_sessions_rls.sql`; `V40_modulo_nutricionista.sql`; `V46_server_controlled_profile_authorization.sql`; `docs/BASELINE_BANCO.md`. Elemento analisado: acesso direto, RLS, autorização pendente e baseline. Confiança: confirmada no repositório; produção não verificada remotamente.

Usuário no navegador

- > React + Vite
 - > Supabase Auth
 - > PostgREST / PostgreSQL + RLS
 - > Supabase Storage
 - > Express ou Vercel Functions
 - > Google Gemini
 - > Meta WhatsApp Graph API
 - > Webhook -> Supabase com service role

5. Arquitetura atual

5.1 Visão geral

Camada	Implementação	Evidência	Confiança
Frontend	SPA React + TypeScript + Vite	src/App.tsx, src/main.tsx	Confirmada
Roteamento	React Router	src/App.tsx:349-550	Confirmada
Gateway de dados	classe estática SupabaseService	services/SupabaseService.ts	Confirmada
Banco/API	Supabase/PostgreSQL/PostgREST	cliente e migrations	Confirmada
Autenticação	Supabase Auth	supabaseClient.ts, authenticate	Confirmada
Autorização	UI + profiles + JWT metadata + RLS	migrations V11-V45; V46 pendente	Confirmada
Backend auxiliar	Express e funções Vercel	server.mjs, api/	Confirmada
Arquivos	Supabase Storage	buckets no código	Confirmada no cliente
PDF/documentos	HTML e jsPDF no navegador	componentes e utilitários	Confirmada
Deploy	dist/ versionado, Hostinger	AGENTS.md, package.json	Documentada
Desenvolvimento	Vite local	npm run dev	Confirmada
Homologação	não localizada	apenas planos	Não confirmada

5.2 Estrutura frontend

Há duas organizações coexistentes:

- estrutura mais recente em `src/`, com rotas, páginas, features, layouts e hooks;
- telas históricas em `components/`, ainda ativas e importadas por `src/App.tsx`.

Arquivos especialmente grandes concentram múltiplos domínios, destacando-se `components/ClinicalPages.tsx`, `components/RoleDashboards.tsx` e `services/SupabaseService.ts`. Isso aumenta o custo de reutilização direta em mobile e o risco de regressões.

5.3 Estrutura backend

O backend principal de dados é o Supabase. Express e funções Vercel são usados para operações que exigem credenciais privilegiadas ou comunicação externa:

- geração Gemini;
- envio WhatsApp;
- webhook WhatsApp;
- hospedagem de `dist/` pelo Express, quando utilizado.

Não existe uma API de domínio completa separando todos os clientes do banco. Para a maior parte das operações, o “backend” é PostgREST/RLS acessado diretamente.

6. Tecnologias utilizadas

Tecnologia	Uso	Fonte
React 18.3.1	interface web	package.json
TypeScript 5.8.2	tipagem	package.json
Vite 6.2	build e desenvolvimento	package.json, vite.config.ts
React Router DOM 7.13	rotas	src/App.tsx
Tailwind CSS 3.4	design system	tailwind.config.js
Supabase JS 2.91	Auth, PostgREST, RPC e Storage	supabaseClient.ts, SupabaseService.ts
PostgreSQL/RLS	persistência e autorização	migrations
Express 4.19	API e servidor	server.mjs
Vercel Functions	APIs serverless	api/
Google Gemini	geração de documentos	api/gemini, geminiService.ts
WhatsApp Graph API	confirmação de agenda	server.mjs, api/whatsapp
jsPDF/AutoTable	geração de PDF	componentes de documentos/relatórios
Recharts	dashboards	RoleDashboards.tsx e afins
PapaParse	CSV	CSVImporter.tsx
Lucide React	ícones	componentes e package.json
Vitest	testes	package.json, arquivos *.test.ts
ViaCEP	endereços	services/CEPService.ts

Não foram encontradas dependências de React Native, Expo, Flutter, Capacitor, Cordova, Workbox ou infraestrutura PWA/push.

7. Inventário funcional de módulos

Módulo	Existe?	Estado aparente	Usuários	Funções	Evidências
Autenticação	Sim	Funcional	Todos	login, recuperação, troca obrigatória, sessão	Login.tsx; SupabaseService.ts:385-667
Dashboards	Sim	Funcional, heterogêneo	Todos	métricas por role/especialidade	RoleDashboards.tsx; App.tsx:363-433
Alunos/ficha âncora	Sim	Funcional	Gestão, escola e especialistas	cadastro, busca, responsáveis, escola, documentos	RegistrationForm.tsx; PatientList.tsx
Prontuário	Sim	Funcional, mas incompleto	Especialistas e gestão	ficha, sessões, histórico e documentos	PatientProfile.tsx; ClinicalPages.tsx
Escolas	Sim	Funcional	Gestão e secretarias	CRUD, vínculos e exportação	SchoolManagement.tsx; SupabaseService.ts:2057-2177
Agendamentos	Sim	Funcional	Gestão, recepção e especialistas	agenda, conflito, confirmação e status	SchedulingCenter.tsx; AppointmentForm.tsx
Agenda profissional	Sim	Funcional	Especialistas	agenda diária, iniciar e encerrar	AgendaProfissional.tsx
Sessões clínicas	Sim	Funcional com risco RLS	Especialistas	anamnese, evolução e sessões	ClinicalPages.tsx; clinical_sessions
Psicologia	Sim	Funcional	Psicólogo	dashboard, prontuário e sessões	rotas /app/psychology*
Psicopedagogia	Sim	Funcional, UI híbrida	Psicopedagogo	anamnese V3, sessão e Portage	ClinicalPages.tsx; src/features/psychopedagogy
Fonoaudiologia	Sim	Funcional	Fonoaudiólogo	prontuário e sessões	rotas /app/speech-therapy*
Terapia ocupacional	Sim	Funcional	Terapeuta ocupacional	prontuário e sessões	rotas /app/occupational-therapy*
Fisioterapia	Sim	Funcional	Fisioterapeuta	prontuário e sessões	rotas /app/physiotherapy*
Serviço social	Sim	Funcional, fragmentado	SPECIALIST de Serviço Social	entrevistas, casos, agenda e sessões	SocialServiceHub.tsx; SocialServiceInterviewHub.tsx
Nutrição	Sim	Funcional, incompleto	Nutricionista e gestão	avaliação, antropometria, NAE, EAN e evolução	V40; rotas /app/nutricion/*
Portage	Sim	Funcional	Especialistas	avaliação de desenvolvimento	PortageCalculator.tsx; testes de lógica
Documentos/IA	Sim	Funcional com riscos	Especialistas e gestão	Gemini, fallback, HTML/PDF e registro	DocumentGenerator.tsx; geminiService.ts
Cofre/anexos	Sim	Funcional; privacidade não confirmada	Gestão e especialistas	upload, listagem e download	DocumentVault.tsx; Storage
Atestado	Sim	Funcional, SQL inseguro	Conforme UI	validação do agendamento e PDF	AtestadoComparecimento.tsx; V43
Profissionais de apoio	Sim	Funcional	Gestão, secretarias e escola	cadastro, vínculo, documentos e soft delete	SupportProfessionalManagement.tsx; V29-V34
Mensagens/notificações	Sim	Funcional	Todos	caixa interna, alertas e leitura	MessagingSystem.tsx; NotificationContext.tsx
WhatsApp	Sim	Funcional; webhook vulnerável	Agenda/gestão	envio, confirmação e cancelamento	server.mjs; api/whatsapp
Relatórios	Sim	Funcional, validações pendentes	Gestão/especialistas	TEA/ANEE, TCM, gerenciais e nutrição	rotas relatorio-*
Auditoria	Sim	Funcional; INSERT forjável em V28	ADMIN e Educação	consulta e registro de eventos	AuditLogs.tsx; V28
Backup	Sim	Funcional; alto risco no cliente	ADMIN	snapshot local, JSON e restauração	BackupSystem.tsx; backupService.ts
Configurações	Sim	Funcional	ADMIN na navegação	identidade e papel timbrado	SystemSettings.tsx; PapelTimbradoConfig.tsx

Módulo	Existe?	Estado aparente	Usuários	Funções	Evidências
Importação CSV	Sim	Funcional	Gestão	importação em massa	<code>CSVImporter.tsx</code>
Financeiro/caixa	Não	Ausente	-	-	nenhuma entidade/rota encontrada
Portal de responsáveis	Não confirmado	Planejado ou externo	-	-	sem rota/tela; tabelas <code>portal_*</code> apenas documentadas
Clínicas como entidade	Não	Ausente	-	usa SEDE/COCAL e escolas	<code>appointments.unit</code> ; <code>schools</code>

8. Perfis, permissões e escopos

8.1 Perfis confirmados

Perfil técnico	Nome apresentado	Finalidade	Escopo aparente
ADMIN	Administrador	governança global	Global
SPECIALIST	Especialista ou especialidade	atendimento clínico	profissional, especialidade e aluno vinculado
ASSISTANT	Assistente/Recepção	operação administrativa	global ou regional
EDUCATION_SECRETARY	Secretário(a) de Educação	gestão e relatórios	rede/global ou scope
SECRETARIA_SEDE	Secretária Sede	operação regional	Sede
SECRETARIA_COCAI	Secretária Cocal	operação regional	Cocal
COORDENADOR	Coordenador(a)	gestão interna prevista	não uniformemente confirmado
ESCOLA	Escola	gestão da unidade	própria escola
SOCIAL_WORKER	sem interface consistente	role previsto	não confirmável

Na prática, Serviço Social está implementado principalmente como **SPECIALIST** com a especialidade **Serviço Social**, não como role **SOCIAL_WORKER**.

8.2 Matriz de capacidades aparentes

Perfil	Visualiza	Cria	Edita	Exclui	Aprova/confirma	Escopo dos dados
ADMIN	Sim	Sim	Sim	Sim/RPC, com riscos	Sem aprovação genérica	Global
SPECIALIST	Sim	sessões, agenda limitada e cadastro rápido	próprios registros/partes clínicas	Não confirmado com segurança	status do próprio atendimento	profissional, especialidade e vínculo
ASSISTANT	Sim	agenda e cadastros operacionais	operacional	Parcial	confirmação de agenda	global ou regional
EDUCATION_SECRETARY	Sim	cadastros/documentos	gestão e relatórios	Não confirmado	não há aprovação genérica	rede/global ou scope
SECRETARIA_SEDE	Sim	agenda/cadastros	operacional	Parcial	confirmação de agenda	Sede
SECRETARIA_COCCAL	Sim	agenda/cadastros	operacional	Parcial	confirmação de agenda	Cocal
COORDENADOR	Previsto	Previsto	Previsto	Não confirmado	Não confirmado	indefinido/inconsistente
ESCOLA	Sim	apoio e possíveis dados próprios	vínculos próprios	Não	Não	school_id/INEP
SOCIAL_WORKER	Não confirmável	Não confirmável	Não confirmável	Não	Não	inconsistente

8.3 Camadas de validação

- `ProtectedRoute` verifica apenas a presença de usuário.
- Menus em `Layout.tsx` ocultam itens por role/especialidade.
- `/app/admin` possui guarda visual de ADMIN.
- `/app/audit-logs` permite ADMIN e `EDUCATION_SECRETARY`.
- Outras rotas administrativas não possuem gate central uniforme.
- RLS é a autoridade final para chamadas diretas ao Supabase.
- APIs Gemini e WhatsApp consultam `profiles.is_active` e role server-side.
- O estado documentado de produção até V45 ainda mantém dependência de metadata em policies.

Conclusão: a autorização está distribuída e inconsistente entre UI, `profiles`, JWT metadata, APIs e RLS. Evidência: `src/routes/ProtectedRoute.tsx`; `src/App.tsx:520-546`; `components/Layout.tsx:160-318`; `server/authorization.mjs`; migrations V11-V46. Elemento analisado: guardas de rota, menus, normalização de perfil e policies. Confiança: confirmada.

9. Fluxos principais

9.1 Login e sessão

1. Usuário acessa `/login`.
2. `SupabaseService.authenticate` chama `signInWithPassword`.

3. O perfil é carregado de `profiles`.
4. Perfil inexistente, inativo ou com role inválido é recusado e ocorre `signOut`.
5. O aplicativo carrega escolas e alunos conforme o perfil.
6. Sessão persiste em `localStorage` e renova automaticamente.
7. Timeout é de 30 minutos para alguns perfis administrativos e 60 minutos para os demais.
8. A troca obrigatória de senha bloqueia o restante da aplicação.

Risco: o logout manual de `src/App.tsx:293-296` apenas limpa o estado e navega; o logout automático efetivamente chama `supabase.auth.signOut()`.

9.2 Cadastro do aluno

1. Gestão abre `/app/register`.
2. Preenche identificação, responsáveis, endereço, escola, informações sociais e documentos.
3. O formulário consulta possíveis duplicidades.
4. `saveStudent` realiza insert/update.
5. Foto vai para `students-photos`.
6. Documentos vão para `student-documents` e seus metadados são mantidos no aluno.
7. A ação é registrada em `audit_logs` pelo cliente.

Riscos: URLs públicas, regras importantes no cliente, dados clínicos no JSONB do aluno e método de exclusão física ainda disponível.

9.3 Consulta de alunos e prontuário

1. `App.tsx` carrega lista compacta após sessão válida.
2. Listagens filtram `status = 'Active'`.
3. Perfil ESCOLA é filtrado por `school_id` no cliente, além da RLS.
4. Especialistas restritos consultam agendamentos e extraem IDs de alunos vinculados.
5. Ao abrir o prontuário, dados completos e sessões são carregados separadamente.
6. Sessões, documentos, Portage e informações por especialidade compõem a ficha.

Risco: navegação ainda depende parcialmente de estado React/localStorage; IDs não são usados de modo uniforme nas rotas.

9.4 Agendamento e confirmação

1. Usuário abre a central ou novo agendamento.
2. Seleciona escola, aluno, especialidade, profissional, unidade, data e horário.
3. O cliente consulta conflitos de profissional e aluno.
4. Persiste em `appointments` com status inicial.
5. Pode enviar confirmação WhatsApp.
6. API de envio valida sessão, perfil e acesso ao agendamento.
7. Webhook recebe resposta e altera status.

Riscos: transições distribuídas, webhook sem assinatura e ausência de idempotência.

9.5 Início, evolução e encerramento

1. Especialista abre agenda pessoal.
2. `iniciarAtendimento` altera para `EM_ATENDIMENTO`.
3. O aluno é carregado.
4. A tela clínica grava `clinical_sessions`.
5. Vários fluxos também atualizam `students.clinical_info`.
6. O atendimento pode ser encerrado com status `ENCERRADO`.

Risco: V39 valida o INSERT somente por `professional_id = auth.uid()`, sem demonstrar vínculo com aluno ou correspondência da especialidade.

9.6 Documento oficial com IA

1. Usuário seleciona aluno e tipo de documento.
2. Frontend monta prompt com contexto pessoal/clínico.
3. Envia para `/api/gemini/generate` com bearer token Supabase.
4. Backend valida sessão e perfil ativo.
5. Gemini gera o conteúdo; se falhar, há template local.
6. O documento é salvo em `generated_documents` e pode ser exportado.

Riscos: minimização de PII, quota por usuário, observabilidade e escape de HTML ainda insuficientes.

9.7 Nutrição

O fluxo cobre avaliação, antropometria, NAE, EAN, evolução e relatórios. A persistência ocorre em tabelas `nutrition_*`. Existem duas famílias de rotas/telas nutricionais, e V40 não aplica integralmente o recorte por aluno, especialidade e região.

9.8 Administração de usuários

ADMIN lista perfis, cria conta Auth, grava `profiles`, define role/especialidade, redefine senha e tenta excluir via `delete_user_complete`. Algumas RPCs não possuem definição canônica na cadeia versionada. O signup genérico ainda possui role padrão ADMIN, embora o acesso efetivo dependa de `profiles` e RLS.

9.9 Backup e restauração

O navegador consulta dados, cria JSON, mantém snapshots em `localStorage`, permite download e restauração modular. É funcional para o web atual, mas inadequado para um cliente mobile devido à materialização de dados pessoais e clínicos no dispositivo.

10. Banco de dados e entidades

10.1 Mapa simplificado

Entidade	Finalidade	Relacionamentos	Sensibilidade	Potencial mobile
profiles	identidade, role e escopo	auth.users, escola	Alta	autenticação/autorização
schools	unidades escolares	alunos, perfis e apoio	Média	filtros e contexto
students	ficha âncora	escola, agenda e sessões	Muito alta	consulta mínima controlada
appointments	agenda	aluno e profissional	Alta	agenda do dia
clinical_sessions	evolução clínica	aluno, profissional e especialidade	Muito alta	registro controlado
profissional_aluno_vinculo	vínculo explícito	aluno e profissional	Alta	autorização
generated_documents	documentos oficiais	aluno e emissor	Muito alta	consulta limitada
attendance_certificates	atestados	agendamento/emissor	Alta	baixa prioridade
support_professionals	cuidadores e vínculos	escola e aluno	Alta	trabalho de campo
audit_logs	trilha de ações	usuário e módulo	Alta	administração, não MVP
system_messages	mensagens	remetente/destinatário	Alta	notificações
system_settings	configuração global	sistema	Média	leitura
letterhead_config	papel timbrado	unidade	Média	documentos
nutrition_assessments	avaliação	aluno/profissional	Muito alta	coleta controlada
nutrition_anthropometry_history	medidas	aluno/avaliação	Muito alta	coleta em campo
nutrition_nae	necessidades alimentares	aluno/profissional	Muito alta	consulta controlada
nutrition_ean_activities	atividades EAN	profissional	Alta	registro em campo
nutrition_evolution	evolução nutricional	aluno/profissional	Muito alta	registro controlado
portal_config, portal_perfis, portal_sistemas	portal documentado	não confirmado no app	Variável	não confirmado

10.2 Funções e RPCs relevantes

- can_select_student;
- can_insert_student;
- can_update_student_clinical;
- regional_district_cap;
- row_matches_regional_school;

- `appointments_is_scheduling_staff` e `appointments_is_admin`;
- `prontuario_status_agendamento_vinculo`;
- `prontuario_especialidades_restritas`;
- `support_professionals_can_manage`;
- `support_professionals_escola_can_write_school`;
- `clear_must_change_password`;
- `delete_user_complete`;
- `set_user_password`;
- `merge_students`.

10.3 Migrations, RLS e baseline

- Migrations documentadas como aplicadas: V11 a V45.
- V46 existe localmente, mas está bloqueada e não aplicada.
- Existem duas V38.
- Há um arquivo prefixado por data antes das Vxx.
- V11/V13 dependem de `support_professionals`, cujo DDL canônico não está na sequência.
- V15 depende de `appointments`, definida em SQL avulso.
- `profiles.school_id`, `generated_documents`, algumas RPCs e policies de Storage não têm origem canônica completa.
- O enum inicial de roles não contém todos os valores atuais.
- SQLs avulsos incluem operações destrutivas e desativação de RLS, portanto não formam uma baseline aplicável em lote.

Conclusão: o banco não é reproduzível do zero apenas com a cadeia versionada disponível. Evidência: `docs/BASELINE_BANCO.md`; `supabase_schema.sql`; `db/migrations/`. Elemento analisado: pré-requisitos, migrations duplicadas, DDLs ausentes e objetos usados pelo frontend. Linhas: `docs/BASELINE_BANCO.md`: 34-104. Confiança: confirmada localmente.

10.4 Armazenamento de arquivos

Buckets observados:

- `students-photos`;
- `student-documents`.

O cliente chama `getPublicUrl` após uploads. Não foi localizada uma cadeia canônica completa de policies de Storage que comprove privacidade. Para mobile, os buckets devem ser privados, com URLs assinadas de curta duração e autorização por objeto.

11. Comunicação frontend/backend

Operação	Forma atual	Camada	Segurança aparente	Adequação mobile
Login/sessão	Supabase Auth direto	Cliente/Supabase	boa base; token persistente	Reutilizável com ajustes
Listar alunos	PostgREST direto	Cliente + RLS	depende da RLS	Reutilizável com ajustes
Gravar aluno	PostgREST + Storage	Cliente + RLS	regras importantes no cliente	Deve usar API/RPC em operações sensíveis
Agenda	PostgREST direto	Cliente + RLS	parcial	Reutilizável com ajustes
Sessão clínica	PostgREST direto	Cliente + RLS	V39 insuficiente	Deve ser protegida por API/RPC
Usuários/senhas	Auth, tabelas e RPC	Cliente/Supabase	privilegiada/inconsistente	Inadequada para exposição mobile
Gemini	API autenticada	Backend	chave server-side; falta minimização/quota	Reutilizável com ajustes
WhatsApp envio	API autenticada e escopada	Backend	boa evolução recente	Reutilizável com ajustes
WhatsApp webhook	service role	Backend	sem assinatura/idempotência	Precisa ser redesenhada
Upload	Storage e URL pública	Cliente	privacidade não comprovada	Bucket privado/URL assinada
Documentos/PDF	navegador	Cliente	materializa dados	Reutilizável com ajustes
Backup/restauração	navegador/localStorage	Cliente	alto risco	Inadequada para mobile
Auditoria	INSERT pelo cliente	Cliente + RLS	evento forjável	Deve usar API/RPC
Notificações	<code>system_messages</code>	Cliente	não é push nativo	Reutilizável com ajustes
ViaCEP	chamada externa	Cliente	baixo risco relativo	Reutilizável

12. Autenticação, autorização e segurança

12.1 Autenticação

O cliente Supabase usa:

- `persistSession: true;`
- `autoRefreshToken: true;`
- `detectSessionInUrl: true;`
- `localStorage` quando disponível, com fallback em memória.

Login atual:

- valida credenciais no Supabase Auth;
- consulta `profiles`;

- exige `is_active === true`;
- valida role contra lista permitida;
- encerra a sessão se o perfil não for autorizável.

12.2 Autorização server-side atual

`server/authorization.mjs` e `api/_shared/authorization.ts` obtêm identidade Auth, consultam `profiles` usando cliente privilegiado e autorizam Gemini/WhatsApp por role e escopo.

O envio WhatsApp também valida o agendamento:

- ADMIN e COORDENADOR: acesso global;
- SPECIALIST: apenas próprio agendamento e especialidade;
- secretarias: unidade/distrito correspondente;
- ASSISTANT e EDUCATION_SECRETARY: scope global ou regional.

Problemas:

- role inexistente `SECRETARIA_EDUCACAO` permanece aceita no backend;
- `SOCIAL_WORKER` não é aceito;
- o webhook de entrada não valida `X-Hub-Signature-256`;
- não foi encontrada deduplicação de eventos.

12.3 RLS e metadata

Migrations V11-V45 possuem combinações de autorização via `auth.jwt()->'user_metadata'->>'role'` e consultas a `profiles`. A V46 pretende tornar `profiles` a única fonte, proteger campos autorizativos e substituir policies, mas não foi aplicada.

Enquanto esse estado persistir, um aplicativo adicional aumentaria a superfície de exploração das mesmas policies. O cliente nunca deve ser tratado como autoridade; toda permissão deve ser verificável no banco ou backend.

12.4 Auditoria

`audit_logs` registra ações, mas V28 permite INSERT a qualquer autenticado. Como o texto do evento é montado pelo cliente, um usuário pode potencialmente produzir registros falsos. Auditoria mobile deve ser append-only, gerada por função server-side com identidade e contexto derivados da sessão.

12.5 Dados e segredos

A auditoria anterior registrou existência histórica de chaves, tokens aparentes e arquivos com dados pessoais em artefatos rastreados. Nenhum valor foi lido ou reproduzido neste relatório. Todo valor sensível deve ser tratado como `[SEGREDO OCULTADO]`.

13. Funcionalidades com potencial mobile

Funcionalidade atual	Origem	Usuário	Relevância	Motivo	Dependências	Riscos
Agenda do dia	Agenda	Especialista	Alta	uso rápido durante atendimentos	RLS e status	exposição da agenda
Confirmar chegada/presença	Agenda	Recepção	Alta	operação de balcão	transição server-side	atualização indevida
Iniciar/encerrar atendimento	Agenda clínica	Especialista	Alta	ação contextual	API/RPC	duplicidade/conflito
Consulta essencial do aluno	Prontuário	Especialista/escola	Alta	mobilidade e campo	payload mínimo	excesso de PII
Registro de evolução	Sessões	Especialista	Alta	próximo ao atendimento	RLS forte	dado clínico/offline
Foto/scanner	Cadastro/cofre	Gestão autorizada	Alta	câmera agrega valor	Storage privado	consentimento/EXIF
Mensagens e pendências	Mensageria	Todos	Alta	comunicação imediata	push seguro	PII na notificação
Cadastro rápido	Alunos	Especialista	Alta	fluxo já existe	duplicidade	cadastro incompleto
Antropometria/NAE	Nutrição	Nutricionista	Alta	coleta em campo	validação e sync	dado clínico
Profissionais de apoio	Apoio	Secretaria/escola	Moderada	consulta em campo	escopo escolar	documentos pessoais
Documentos emitidos	Cofre	Especialista/gestão	Moderada	consulta controlada	URL assinada	compartilhamento externo
Indicadores resumidos	Dashboard	Gestão	Moderada	acompanhamento executivo	agregação server-side	inferência de dados
Portage	Clínica	Especialista	Moderada	coleta estruturada	UX tablet	formulário extenso
Relatórios TEA/TCM completos	Relatórios	Gestão	Baixa	melhor em tela grande	grande volume	exposição de PII
Configurações/papel timbrado	Administração	ADMIN	Baixa	pouco ganho móvel	autorização	alteração global
Gestão de usuários	Administração	ADMIN	Não recomendada	operação privilegiada	backend administrativo	escalonamento
Backup/restauração	Backup	ADMIN	Não recomendada	materializa base	arquivo completo	vazamento/corrupção
Merge/exclusões	Administração	ADMIN	Não recomendada	destrutiva	fluxo controlado	perda de dados
Financeiro	-	-	Não aplicável	módulo ausente	-	-

13.1 Recorte funcional provável para estudo de MVP

Sem definir tecnologia ou produto final, o conjunto de maior valor é:

1. autenticação segura;
2. agenda do dia;
3. ações de chegada, início e encerramento;
4. consulta mínima do aluno vinculado;
5. evolução clínica com rascunho controlado;

- 6. cadastro rápido;
- 7. anexos com câmera/scanner;
- 8. mensagens e pendências;
- 9. recursos nutricionais de campo.

14. Recursos nativos aplicáveis

Recurso	Caso de uso no Brotar	Valor	Risco	Prioridade
Push	agenda, alertas e mensagens	Alto	PII na tela bloqueada	Alta
Biometria/Face ID	desbloqueio local	Alto	não substitui Auth/RLS	Alta
Câmera	foto e anexos	Alto	consentimento e EXIF	Alta
Scanner	RG, CPF, laudos, certificados	Alto	documento sensível	Alta
Tablet	formulários clínicos/nutrição	Alto	responsividade atual	Alta
Calendário	agenda profissional	Médio/alto	vazamento no calendário pessoal	Moderada
Voz para texto	evolução clínica	Médio	terceiro processando dado clínico	Moderada
Assinatura na tela	documentos/atestados	Médio	validade/não repúdio	Moderada
Compartilhamento seguro	PDF/documento	Médio	cópia em apps externos	Moderada
Offline	escolas sem conexão	Potencialmente alto	conflitos e cache clínico	Somente após redesenho
QR Code	validação futura de documento	Médio	verificador ainda ausente	Baixa/moderada
Localização	nenhum caso obrigatório	Baixo	rastreamento desnecessário	Não recomendada
Áudio	nenhum fluxo atual comprovado	Incerto	dado biométrico/clínico	Não recomendada agora

14.1 Requisitos mínimos para push

- payload sem nome, diagnóstico, escola ou especialidade;
- mensagem genérica, como “Você possui uma nova atualização”;
- conteúdo real somente após desbloqueio e autorização;
- registro e revogação de dispositivo;
- preferência do usuário e política institucional;
- remoção de token em logout ou desativação de conta.

14.2 Requisitos mínimos para offline

Offline não deve entrar automaticamente no primeiro MVP. Antes, seriam necessários:

- classificação de campos que podem ser armazenados;
- criptografia local;
- expiração e limpeza remota;
- versionamento de registros;

- fila transacional;
- regras de conflito;
- auditoria de sincronização;
- testes de perda, reinstalação e múltiplos dispositivos.

15. Prontidão técnica para Android e iOS

15.1 Classificação geral

Prontidão: baixa.

Dimensão	Avaliação	Justificativa
Domínio funcional	Boa	módulos e fluxos reais estão presentes
Separação de camadas	Baixa	regras e acesso direto concentrados no cliente
Autenticação	Moderada/boa	Supabase Auth funcional; precisa storage seguro/revogação
Autorização	Baixa	V46 bloqueada e políticas históricas divergentes
RLS	Moderada em cobertura, baixa em garantia	existe, mas há lacunas e falta teste remoto
APIs	Baixa/moderada	Gemini/WhatsApp cobertos; domínio geral sem API
Storage	Baixa	<code>getPublicUrl</code> e políticas não reconciliadas
Auditoria	Baixa	eventos criados pelo cliente
Migrations	Baixa	baseline não reproduzível
Homologação	Muito baixa	ambiente não confirmado
Testes	Baixa	poucos contratos e RLS dependente de credenciais
Mobile/offline/push	Muito baixa	infraestrutura inexistente
Responsividade/tablet	Baixa/moderada	bugs documentados em tabelas, sidebar e gráficos

15.2 Evidências de prontidão

Conclusão: o backend funcional pode ser compartilhado apenas depois de estabilização da autorização. Evidência: V39, V40, V46 e [.brotar-docs/04-BUGS-E-PENDENCIAS.md](#).

Elemento analisado: RLS clínica/nutricional e V46 bloqueada. Confiança: confirmada localmente.

Conclusão: o frontend atual não constitui uma API estável para outro cliente. Evidência: [services/SupabaseService.ts](#). Elemento analisado: consultas PostgREST, RPC e Storage diretas. Linhas: métodos `getStudents`, `saveStudent`, `saveSession`, `getAppointments`, `saveAppointment`, `uploads` e `nutrição`. Confiança: confirmada.

Conclusão: identidade e integrações externas foram endurecidas recentemente. Evidência: `SupabaseService.authenticate`; `server/authorization.mjs`; `api/_shared/authorization.ts`. Elemento analisado: perfil ativo e role obtidos de `profiles`. Confiança: confirmada.

Conclusão: não há baseline reproduzível nem homologação comprovada. Evidência: [docs/BASELINE_BANCO.md](#). Elemento analisado: conflitos de pré-requisitos e migrations. Confiança: confirmada.

16. Componentes reutilizáveis e adaptações

16.1 Reutilizáveis

- modelo conceitual de alunos, escolas, perfis, agenda e sessões;
- Supabase Auth, com armazenamento seguro do token;
- convenções de status de agendamento;

- helpers de escola, região, profissional e especialidade;
- APIs autenticadas de Gemini e envio WhatsApp;
- regras de conflito de agenda, após mover para servidor/RPC;
- lógica Portage e classificação de especificidade;
- normalizadores CSV, validadores e formatadores independentes de DOM;
- estruturas de nutrição;
- design system e identidade visual como referência;
- regras funcionais de relatórios, sem necessariamente reaproveitar jsPDF/browser.

16.2 Exigem adaptação

- `SupabaseService`: separar contratos de domínio de implementação web;
- autenticação: usar armazenamento seguro e gestão de dispositivos;
- navegação: usar IDs persistentes e deep links consistentes;
- documentos: geração/download seguro e cache temporário;
- notificações: substituir polling por infraestrutura push;
- uploads: bucket privado, compressão, scanner e retry;
- formulários clínicos: modularização e experiência tablet/mobile;
- dashboards: agregações server-side e payloads menores;
- logs: eventos server-side;
- agenda: transições e conflitos transacionais.

16.3 Não devem ser expostos diretamente

- service role Supabase;
- chaves Gemini e WhatsApp;
- criação/alteração de roles;
- reset administrativo de senha;
- `delete_user_complete`;
- merge e exclusões de alunos;
- backup/restauração completos;
- emissão oficial de atestado sem autoridade server-side;
- manipulação direta de `audit_logs`;
- configurações globais;
- webhook WhatsApp;
- URLs públicas permanentes de documentos.

16.4 Componentes ausentes

- API de domínio versionada;
- baseline canônica do banco;
- ambiente de homologação confirmado;
- testes RLS por matriz completa;
- device registry e revogação;
- serviço push;
- política de cache e limpeza local;
- sincronização/conflitos offline;
- observabilidade por cliente/versão;
- termos e controles mobile LGPD;

- contratos de payload gerados do schema.

16.5 Ajustes prioritários antes do MVP

1. Reconciliar schema remoto e migrations.
2. Corrigir/testar o sucessor seguro da V46 em homologação.
3. Remover metadata editável como autoridade das policies.
4. Gerar tipos a partir do schema real.
5. Criar APIs/RPCs para sessões, atestados, auditoria e administração.
6. Tornar buckets privados e usar URLs assinadas.
7. Validar assinatura e idempotência do webhook.
8. Centralizar transições da agenda.
9. Persistir IDs de entidades nos contratos de navegação.
10. Criar homologação e testes negativos.
11. Definir retenção, cache, revogação e captura de tela.
12. Definir push mínimo e política offline antes da implementação.

17. Riscos e limitações

Risco	Evidência	Probabilidade	Impacto	Relevância mobile	Recomendação
Escalonamento via metadata	polices anteriores à V46	Alta	Crítico	Muito alta	profiles/app metadata controlada e testes negativos
Acesso entre regiões/escolas	V27/V36 e OR de polices	Média/alta	Alto	Alta	matriz única de autorização
Sessão sem vínculo/especialidade	V39	Alta	Crítico	Muito alta	RPC/API transacional
Nutrição com RLS insuficiente	V40	Alta	Alto	Alta	validar aluno, profissional, especialidade e região
Atestados forjáveis	V43 USING/WITH CHECK (true)	Alta	Crítico	Média	emissão server-side
URL pública de documentos	getPublicUrl	Alta	Crítico	Muito alta	bucket privado/URL assinada
Webhook sem assinatura	ausência de HMAC	Alta	Alto	Indireta	X-Hub-Signature-256
Falta de idempotência	webhook	Média	Alto	Indireta	deduplicar event ID
Logout manual incompleto	App.tsx:293-296	Alta	Alto	Alta	chamar signOut e revogar dispositivo
Dados clínicos locais	sessão e backup em localStorage	Média	Crítico	Muito alta	secure storage e cache mínimo
Backup completo no cliente	backupService.ts	Alta	Crítico	Muito alta	não expor no app
Auditoria forjável	V28	Alta	Alto	Alta	audit RPC server-controlled
Exclusões físicas disponíveis	métodos delete	Média	Alto	Alta	soft delete e API restrita
Drift de schema	baseline e duas V38	Alta	Alto	Alta	ledger e baseline reconciliada
Roles divergentes	types.ts x backend	Alta	Médio/alto	Alta	contrato único
Push com PII	risco futuro	Média	Alto	Direta	payload genérico
Offline e conflitos	estratégia ausente	Alta se adotado	Crítico	Direta	não incluir no primeiro MVP
Segredos/dados históricos	auditoria técnica	Documentada	Crítico	Indireta	rotação e resposta a incidente
Falta de homologação	apenas planos	Alta	Alto	Alta	ambiente isolado
Cobertura de integração baixa	testes existentes	Alta	Alto	Alta	testes por contrato mobile
HTML sem escape uniforme	templates/impressão	Média	Alto	Média	sanitização rigorosa
Monólitos frontend	arquivos extensos	Alta	Médio	Alta	modularizar por domínio
Responsividade incompleta	bugs 03-07	Alta	Médio	Alta	validar celular e tablet

17.1 Segredos e dados históricos

A auditoria de 05/08 documenta achados históricos em artefatos e histórico Git. Este relatório não contém valores, senhas, tokens, chaves ou URLs privadas. Os arquivos `.env` e `.env.local` não foram abertos.

17.2 Limitações desta análise

- nenhuma confirmação do schema remoto;
- nenhuma inspeção dos buckets reais;
- nenhuma confirmação de migrations aplicadas pelo ledger do Supabase;
- nenhum teste de autorização contra produção;
- nenhum teste visual responsivo nesta etapa;
- nenhum teste de carga;
- nenhuma validação jurídica/LGPD;
- nenhuma entrevista com usuários;
- nenhuma medição de conectividade em campo.

18. Informações ausentes

18.1 Documentação ausente

- contrato canônico do banco;
- catálogo oficial de APIs;
- policies completas dos buckets;
- política LGPD de retenção/descarte;
- continuidade e recuperação;
- arquitetura de homologação;
- contrato de push/dispositivos.

18.2 Regras de negócio não documentadas

- todas as transições válidas de status;
- alta e encerramento clínico;
- validade de assinatura e atestado;
- retenção de rascunhos;
- autoridade para excluir/mesclar alunos;
- acesso integral do coordenador.

18.3 Módulos não confirmados

- portal público relacionado a `portal_*`;
- acesso de responsáveis;
- `FrequenciaPage.tsx`, sem rota principal confirmada;
- agenda/calendário nativo;
- financeiro, aparentemente inexistente.

18.4 Permissões não confirmadas

- policies e grants efetivos no banco remoto;
- versões ativas das RPCs;
- policies de Storage;
- comportamento de `SOCIAL_WORKER`;
- escopo final de `COORDENADOR`.

18.5 Produção e integrações não verificadas

- migrations efetivamente aplicadas;
- privacidade dos buckets;

- logs e incidentes;
- rotação de credenciais;
- versão implantada;
- topologia Hostinger/Vercel ativa;
- assinatura configurada no webhook;
- contratos e base legal para Gemini/Meta.

18.6 Homologação

Nenhum ambiente configurado e verificável foi localizado. A documentação apenas recomenda sua criação e uso.

19. Perguntas para a proprietária

1. Existe homologação Supabase separada e atualizada?
2. Há dump somente de schema do banco atual, sem dados ou segredos?
3. Quais migrations constam oficialmente como aplicadas?
4. Os buckets `student-documents` e `students-photos` são públicos?
5. `SOCIAL_WORKER` deve existir como role ou Serviço Social continuará como especialidade?
6. Qual é o escopo funcional de `COORDENADOR`?
7. Responsáveis terão acesso futuro ou o aplicativo será interno?
8. Quais profissionais trabalham em campo ou sem internet?
9. Evoluções podem ser salvas como rascunho no dispositivo?
10. Quais dados mínimos podem aparecer em push?
11. Há base legal/consentimento para enviar contexto ao Gemini?
12. Quem pode emitir, anular e verificar atestados?
13. WhatsApp é obrigatório para o primeiro MVP?
14. Fotos e documentos podem ser capturados pelo celular?
15. Existe política municipal para aparelhos pessoais?
16. O produto precisa funcionar em tablets institucionais?
17. Quais módulos são usados diariamente fora de computadores?
18. Houve rotação das credenciais citadas na auditoria de 05/08?
19. Hostinger é o único ambiente ou funções Vercel também estão ativas?
20. Qual fonte deve prevalecer para a versão: 2.4.160 ou 2.4.161?
21. Existe SLA esperado para agenda, consulta de aluno e sincronização?
22. É necessário impedir screenshots em telas clínicas?
23. Quais dados podem ser armazenados temporariamente no dispositivo?
24. O dispositivo será institucional, pessoal ou ambos?
25. Existe processo formal de perda/roubo e revogação de aparelhos?

20. Conclusão

O Sistema Brotar possui base funcional suficiente para justificar um futuro aplicativo, especialmente para:

- agenda do dia;
- chegada, início e encerramento de atendimento;
- consulta essencial de aluno vinculado;
- cadastro rápido;
- evolução clínica;

- nutrição em campo;
- captura segura de anexos;
- mensagens e pendências.

Entretanto, o primeiro passo não deve ser escolher React Native, Flutter, Expo, PWA ou tecnologia nativa. Antes, é necessário estabilizar autorização, schema, Storage, homologação, contratos server-side e gestão de dados no dispositivo.

O recorte futuro mais coerente é um MVP interno e restrito, voltado a profissionais autenticados e operações de alta frequência. Administração de usuários, backup, merge/exclusões, configurações globais e relatórios extensos devem permanecer no sistema web inicialmente.

20.1 Declarações finais da análise

- A análise foi realizada sobre arquivos locais do Sistema Brotar.
- Nenhum banco remoto foi acessado.
- Nenhuma migration ou SQL foi executado.
- Nenhum segredo foi exposto.
- Nenhuma dependência foi instalada ou atualizada.
- Nenhuma implementação mobile foi iniciada.
- Nenhuma tecnologia mobile definitiva foi escolhida.
- As conclusões sobre produção são documentais, não resultado de inspeção remota.

Documento gerado exclusivamente a partir da análise dos arquivos locais. Nenhum banco remoto foi acessado e nenhuma migration foi executada.